Securing A Cloud Based Healthcare Application

Authors:
Lindsay Reiter - lreiter
Dhanushree Sidharamanagara Onkaramurthy - dhanuso7
Atharva Vijayanand Gham - avg1024

ENPM665 - Kevin Shivers

Table of Contents:

Infrastructure Changes and Recommended Services Report: 1
Identity and Access Management 1
Virtual Machine Vulnerability Recommendations 2
Network Security Recommendations 3
Data Security Recommendations - Written by Lindsay Reiter 6
Disaster Recovery Recommendations - Written by Lindsay Reiter 7
Proposed Architecture 10

Infrastructure Changes and Recommended Services Report

The MedCircle cloud healthcare application is in need of some changes to ensure that it is secure. The following report will delve into the infrastructure change recommendations for each aspect of the application. The areas addressed are identity and access management, data security, virtual machine security, network security, and ensuring disaster recovery.

Identity and Access Management

Identity and Access Management (IAM) ensures secure control over access to sensitive information and resources. It protects against unauthorized access, data breaches, and insider threats by managing user identities, roles, groups, and permissions. This streamlines user provisioning and de-provisioning processes, reducing the risk of human error and improving operational efficiency. Below are the recommendations that are needed for improving the security posture of the application.

Enforce MFA
It is recommended to use IAM roles for human users to access AWS resources so that they use temporary credentials. However, for scenarios in which an IAM user is needed to be created, they require Multi-factor authentication (MFA) for additional security. In this case, two forms of authentication are required for access. These authentication requirements to complete the sign-in process are a users' own credentials and a device-generated response. Enforcing MFA helps mitigate

the risks associated with compromised passwords, phishing attacks, or other authentication vulnerabilities.

IAM Role permissions
The permissions attached to the IAM roles should be through the IAM policies and not attached directly. It is recommended that the company employ the principle of least privilege for the IAM roles. This means that permissions given to each role should be carefully reviewed and only policies which are absolutely required for that role should be attached and nothing more. Attaching more permissions to roles than are required can lead to security issues like unauthorized access, privilege escalation and also increases the opportunities for attack.

IAM groups and roles
It is always recommended to use IAM roles for human users to access AWS resources so that they use temporary credentials. In this way, the user management and permissions can be securely configured without the need of creating separate users each time a new patient is enrolled. IAM Users should always be part of at least one group. Different groups can be created based on the level of permission needed to be given for different users and resources. A separation of duties can be employed by dividing responsibilities among different IAM roles. This helps prevent a single point of failure and reduces the potential harm of insider threats.

AWS Route53
The next recommendation that needs to be implemented for a secure healthcare infrastructure is the use of AWS Route53 DNS. Route 53 is a scalable cloud Domain Name System (DNS) web service. It is suggested to use Route53 as it helps in registering domain names, routing internet traffic to the resources for our domain, and also checking the health of the resources. Route53 provides reliable domain name services, ensuring efficient management of web traffic. Route 53 is also easily integrated with other AWS services, offering a foundational component for building available and resilient applications in the cloud.

Virtual Machine Vulnerability Recommendations

AWS Systems Manager Patch Manager
The Amazon Machine Images that were used in the infrastructure for web and application servers included outdated and vulnerable binaries and kernels. These unpatched components could serve as potential entry points for attackers, enabling them to exploit the system and gain unauthorized access. Patch Manager is a recommended service provided by AWS which helps in automating the patching of nodes with security and other updates. The automation of this service simplifies the task of keeping instances up-to-date with the latest security patches, making it easier to maintain the security and compliance of your infrastructure. This service also provides flexible scheduling and compliance reports that can be used to track the progress of patching activities and ensure that instances are up-to-date.

IAM roles for service accounts
IAM roles for EC2 instances improves security by avoiding the use of long-term credentials as they provide dynamic and automatically rotated temporary credentials. Roles improve scalability and simplify permission management, allowing seamless integration with other AWS services. These

temporary credentials can then be used in the application's API calls to access resources and to limit access to only those resources that the role specifies. The process of attaching the permissions required by the instance can also be easily given through roles.

IMDSv2

IMDSv1 (Instance Metadata Service version 1) vulnerability refers to a security issue associated with the AWS EC2 instance metadata service. In IMDSv1, sensitive information, such as temporary security credentials and other instance metadata, is accessible without proper authentication. This vulnerability could allow attackers who gain access to an EC2 instance to retrieve sensitive data, potentially leading to security breaches or unauthorized access to other AWS resources. It is recommended that the company use IMDSv2, the more secure version of the Instance Metadata Service, which requires explicit token-based authentication, making it significantly more resistant to various types of attacks, including SSRF (Server-Side Request Forgery) attacks.

AWS CloudFront

The other infrastructural change that needs to be done is the use of cloudfront. CloudFront is an AWS content delivery network service that optimizes web content delivery. It expedites load times through edge location caching, diminishing latency. CloudFront offers robust security with denial of service protection and HTTPS support to ensure availability. It also has automatic scalability that allows it to adjust to varying traffic levels seamlessly. CloudFront integrates smoothly with other AWS services for a comprehensive cloud-based solution.

Use of Load Balancers and Auto-Scaling groups

As the number of users might increase in the healthcare infrastructure, the load on the servers will also be increasing. So, it is a must to use auto-scaling groups for the instances that are used for hosting the servers. It enhances the scalability, availability, and cost-effectiveness of applications hosted on Amazon EC2 instances. It also aligns resource capacity with demand, providing a dynamic and responsive infrastructure for a wide range of workloads. With the number of instances auto-scaling we also need to make sure that the network traffic is effectively distributed among these instances without overloading anyone or routing the traffic for an instance that isn't working. So, application load balancers should be used as they automatically distribute incoming application traffic across all the EC2 instances that you are running so that no one instance is overwhelmed.

Network Security Recommendations

VPC Flow Logs

The VPC Flow Log service should be enabled in the VPCs where the instances and RDS are deployed. VPC Flow Logs enables you to capture information about the IP traffic going to and from network interfaces in the VPC. This will help to understand the network flow and will be very useful during incident response and security attacks. It also helps in network monitoring, forensics, real-time security analysis, and expense optimization.The VPC Flow Logs enabled can be directed to S3 buckets or to the CloudWatch alarms, from there they can be sent to a SIEM tool for better visualization and enhancement.

NAT Gateway

To enhance EC2 security, a NAT gateway should be implemented effectively blocking direct inbound internet connections while facilitating controlled outbound access for updates, patches, and backups. We can attain reduced exposure using NAT gateway which places instances in private subnets and only routing outbound traffic through a NAT gateway, we significantly reduce the attack surface of our system. This is crucial for protecting sensitive patient data and complying with healthcare regulations like HIPAA. Also we can tightly control which instances can access external resources by configuring the NAT gateway's access policies. This helps prevent unauthorized access and data leaks. Adding more to improve scalability and cost effectiveness, NAT gateways allow multiple instances to share a single public IP address, reducing the need for individual public IPs for each instance. This can significantly lower our cloud costs and as NAT gateways are managed services, eliminating the need to provision and maintain separate NAT instances. This simplifies our infrastructure and reduces operational overhead. NAT gateways are highly available and redundant, ensuring reliable outbound connectivity for our healthcare management system By centralizing outbound traffic through the NAT gateway, we can easily monitor and log network activity for enhanced security and compliance.

Internet Gateway

The internet gateway bridges the gap between the AWS network and the internet, enabling two-way communication for public subnet resources. IT and patients can access resources using public IPs, but connections are filtered by security groups.This gateway allows patients to securely access their test results and upload documents directly to backend storage like RDS or S3 from the comfort of their own homes. Also, before sending sensitive patient data to the cloud, the gateway filters and pre-processes it on the edge. This reduces the amount of data transferred, minimizing the attack surface for potential cyber threats and improving overall data security. Secondly, many healthcare regulations, like HIPAA, require specific data handling protocols. An internet gateway can be configured to enforce these regulations, ensuring compliance and protecting patient privacy. This gateway aggregates and compresses data from various devices before sending it to the cloud. This reduces bandwidth consumption, lowers cloud storage costs, and improves data transfer speeds. For frequently accessed data, the gateway performs local caching which reduces cloud server load and improves response times for healthcare professionals accessing patient information.

AWS Client VPN

AWS Client VPN is a managed service that enables secure remote access to the AWS resources and on-premises network from any location using OpenVPN-based clients. This makes it a valuable tool for healthcare organizations that need to provide secure access to their systems for authorized users, such as doctors and healthcare staff working remotely who need access to patient records, diagnostic tools, and communication platforms. Also it is even important for administrative staff for billing, scheduling, and accessing sensitive documents remotely. And at last, it is crucial for the IT personnel managing the system for troubleshooting and maintaining systems from anywhere.

Elastic Load Balancer

Elastic load balancer plays a crucial role in ensuring the smooth operation and scalability of healthcare management systems in the cloud with its features like high availability, fault tolerance, elasticity, and cost optimization. Mainly, ELB distributes incoming traffic across multiple instances, like virtual servers or containers, in different Availability Zones (AZs). If one instance fails, ELB automatically routes traffic to the healthy ones, minimizing downtime and ensuring service continuity. This is critical in healthcare, where system outages can have serious consequences for patient care. Also, healthcare systems experience fluctuations in demand, with peak times during appointments or emergencies. ELB can automatically scale up or down the number of instances based on traffic,

optimizing resource utilization and cost. This ensures the system can handle surges without compromising performance. ELB offloads tasks like SSL/TLS termination and health checks from individual instances, freeing them to focus on core application logic which improves overall application performance and responsiveness. Considering security, ELB offers various security features like encryption, access control, DDoS protection, safeguarding sensitive healthcare data, and ensuring compliance with regulations. ELB helps optimize cloud costs by dynamically allocating resources based on demand. You only pay for the instances that are actively serving traffic, maximizing resource utilization and avoiding unnecessary spending.

Amazon web Services Web Application Firewall (AWS WAF)

An AWS Web Application Firewall should be implemented to help shield the healthcare system from common web threats like SQL injection, cross-site scripting (XSS), and bot attacks. These attacks can compromise patient data, disrupt operations, and damage the organization's reputation. As WAF is fully managed by AWS, WAF integrates with other AWS services like CloudFront and Application Load Balancers, simplifying the cloud architecture.

DMZ Subnet

A DMZ subnet should be implemented to create a buffer between the public internet and the internal network where sensitive patient data resides. This isolation minimizes the attack surface and prevents unauthorized access attempts from reaching the core network. By offloading public-facing tasks to the DMZ, the internal network can focus on core tasks like data processing and patient care, improving overall system performance and responsiveness.

Security Groups

Security groups should be utilized in this application as healthcare organizations face the critical challenge of protecting sensitive patient data while maintaining system availability and performance. Traditional network-level firewalls fall short in addressing the granularity and flexibility required for secure healthcare infrastructure. Security Groups, however, offer instance-level control, enabling precise regulation of inbound and outbound traffic for each resource.

Data Security Recommendations - Written by Lindsay Reiter

As it stands right now, this cloud application does not have proper data security. Data security is extremely important when handling sensitive information such as personal health information as this application does. There are regulations such as HIPAA which require applications that handle this data to protect it appropriately. If this data is not protected, not only will the company be non-compliant with regulations, but in the event of a breach there can be serious consequences such as loss of business, loss of revenue, and loss of reputation. The recommendations for ensuring data security of this application will be discussed below.

Enable encryption

The first methodology that should be utilized in the deployment of this application is encryption. Encryption should be enabled for everything including RDS, S3, EBS, and EC2 backups. Not enabling encryption places the application at serious risk. Since the data that this application utilizes is personal health information and personal identifying information, encryption is even more important. Unencrypted data is at great risk of compromise, therefore encryption needs to be enabled.

Multi-AZ deployment

Multi AZ deployment should be utilized for the services that it is available for. Multi AZ deployment is available for S3 and RDS. An AZ is an availability zone and multi AZ suggests that a service is deployed in one zone and then has at least one backup in another availability zone. This promotes redundancy which is a best practice for ensuring data security and availability. If one availability zone were to go down, the data would still be available in another availability zone.

Security best practices

This recommendation is that the IT team follow security best practices. This is very important to ensure data security. Password best practices should be taught and followed including not storing passwords in the open. Password protection along with strong password usage is vital for protecting the data behind the password. Retraining should occur to ensure that all members of the IT team are informed on security best practices and prepared to utilize them in the deployment of this cloud application.

In addition to the above methodologies, there are several services that are recommended to be utilized in order to ensure proper data security. These services will be discussed below:

Amazon Key Management Service (KMS)

AWS KMS is a vital service that is recommended to be implemented into this cloud infrastructure. KMS is as its name suggests, a key management service. The cryptographic keys that are required for encryption to protect the sensitive data that resides within the S3 buckets, RDS, EBS, and EC2 instances can be created and controlled using this service. The entire lifecycle of cryptographic keys can be managed in this service from creation to storage to destruction. This is very important because mishandling of keys can lead to compromise of the sensitive data if the keys were to fall into the wrong hands.

AWS Secrets Manager

AWS Secrets Manager is another recommended service that should be implemented for data security in this application. AWS Secrets Manager is a tool for managing access to resources. It allows for credential rotation and management without disruption to business continuity. It is similar to Key Management Service except that it is for database credentials and other secrets. There are also access management capabilities within this service to ensure that unauthorized access does not happen.

Amazon Macie

Another service that is recommended to be implemented is Amazon Macie. This service uses machine learning to protect the data within AWS S3 buckets. This service allows for analysis of the data within

the application and it is determined whether the data is sensitive or not. Insights from this analysis can then be used to improve the overall data security. This service can make discoveries about data that is improperly stored as well if there was a human error in storing sensitive information in a less secure location.

AWS Glacier

Finally, AWS Glacier is a recommended service that should be implemented in this application. AWS Glacier is utilized for data archival. Glacier provides the capability to archive data for a long term at a low cost if it is not needed often. However it provides fast retrieval if necessary from the archive. This service also integrates with logging services to provide detection capability in the event of a data compromise.

Disaster Recovery Recommendations - Written by Lindsay Reiter

In its current state, the MedCircle healthcare application is not equipped to handle a disaster. It is very important for companies to build their applications to be resilient and to be able to recover in the event of a catastrophe. If an application is not able to recover from a disaster it can cause many issues including loss of business, loss of reputation, loss of revenue, and even up to complete shutdown of the company. Because of how critical disaster recovery is, here are some strong recommendations for ensuring that this company is able to be resilient in the face of adversity.

Create a culture of security

The first methodology that should be employed to ensure that this application is able to recover from a disaster is to create a culture of security within the employees. This team of employees includes the care providers, IT support employees, and the higher up managers. There needs to be buy-in from the upper level management in order to make security and disaster recovery a priority. This will ensure funding is available for the disaster recovery preparation efforts and also will ensure that the team has the right training and human resources in the event of a disaster. There needs to be adequate training or in some cases retraining of the care providers and IT staff so that they can be prepared to handle recovery in the event of a disaster while minimizing the damage.

Implement an Incident Response Plan

The next methodology that should be implemented for this application is an incident response plan. This is a plan of what to do in the event that a disaster occurs. An incident response plan will include a full risk assessment deciding which risks have to be accepted, and which can be mitigated, transferred or avoided. The incident response plan will address the most important, applicable aspects of dealing with a disaster. In this application, there is sensitive data, so a disaster recovery plan needs to include steps of how to secure the personal health data in the event of an issue. There is also the aspect of business continuity that will need to be addressed including how and in what condition business can be conducted to minimize downtime. The incident response plan should have procedures as well as roles and responsibilities laid out.

Maintaining Backups

Another methodology that needs to be implemented to ensure disaster recovery is the maintenance of backups. In the event of deletion, corruption, or any other disruption to availability, it is imperative for recovery that the application have backups. These backups must be appropriately protected through encryption to ensure data security as well. One way that S3 can be protected is through S3 Bucket Versioning. This is where different versions of the bucket and its contained data are kept and then in the event of an issue, can be restored. A recommendation to protect the availability of the RDS would be RDS deletion protection. Deletion protection ensures the availability of the RDS so that it is not able to be deleted by accident in the event of a disaster, human error, or nefarious action.

There are also a number of services that AWS provides which are recommended for MedCircle to implement to assist with disaster recovery. These services will be discussed below:

AWS SecurityHub

AWS SecurityHub is a cloud security posture management (CSPM) service that is currently not enabled in the MedCircle application, but is recommended to be enabled to aid in disaster recovery. SecurityHub is basically a compilation view of many security features that can be enabled. It has a very user friendly dashboard that provides an overview of the security posture of the cloud application. Setting up SecurityHub does not provide any additional monitoring or security on its own, but it provides a convenient way for the IT monitoring team to be quickly apprised of alerts and any security issues so that a disaster can be quickly detected. Early detection of any breaches or other disasters provides the best chance for recovery and mitigation and SecurityHub would contribute to this capability of early detection.

AWS Inspector

AWS Inspector is another early detection service that is recommended to be implemented. Inspector can be integrated into SecurityHub for an all-in-one view of the security status of the application. Inspector itself does exactly what its name suggests, it inspects software and AWS applications for any vulnerabilities or improper exposure. Another key feature of AWS inspector that should be utilized is the mean time to remediate MTTR. AWS inspector supplies a risk score that is based off of the time needed to remediate a disaster. These scores can then be prioritized by the IT team in the event that disaster recovery needs to take place.

AWS CloudWatch

AWS CloudWatch is another service that is highly recommended to be implemented. CloudWatch is a monitoring service that monitors logs, data, and metrics and is capable of sending alerts when something is out of the ordinary. This provides the ability to detect any issues early. CloudWatch has a feature that allows an alarm to be set and then an action taken if that alarm is triggered. This allows for a very quick response to a potential disaster which is best to minimize damage. CloudWatch can be integrated into SecurityHub as well for ease and efficiency in monitoring and responding to incidents.

AWS CloudTrail

AWS CloudTrail is yet another service that should be enabled in order to assist in disaster preparedness. AWS CloudTrail is a logging service which tracks actions and API calls done in the

AWS environment. After a disaster, one of the most important things to have is logs of what happened prior to the disaster. This is helpful in legal situations as well as in lessons learned situations. It is vital to employ CloudTrail so that these logs can be collected and can be utilized in the event of a disaster. Many companies that handle sensitive data are subject to laws such as HIPAA and having CloudTrail logs is one way to prove compliance with these laws. There are analysis features within the logs to help detect suspicious activity and provide yet another early detection service. CloudTrail log files can also be monitored with CloudWatch monitoring.

AWS Shield

AWS Shield is another recommended service for this company to employ. AWS shield protects against denial of service and helps maintain availability as much as possible in the event of one. AWS shield protects the application at the perimeter from network traffic that may be trying to execute a distributed denial of service attack. In the event of a disaster, AWS shield has mitigation capabilities that involve rerouting traffic to allow for availability of services without succumbing to the denial of service attack.

AWS GuardDuty

AWS GuardDuty is a security assessment service that encompasses the entire AWS account. GuardDuty provides continuous monitoring, alerts, and can take action if it is set up to do so. It is specifically a threat detection service as opposed to simply a monitoring service and it will alert if a threat is found. Data from CloudTrails is integrated and analyzed in GuardDuty. Despite it seeming a bit redundant to enable all of these monitoring services, it is important to have all of them enabled because each covers slightly different areas of the application. It is also important to have these services enabled to provide defense in depth in the event that one service misses an issue due to it not being specifically detectable by that service, it will be detected by another.

Proposed Architecture

The attached diagram is a proposed architecture for this cloud based application. The flow through the architecture can be seen from the patient perspective in red, care provider perspective in blue, and IT team perspective in black.

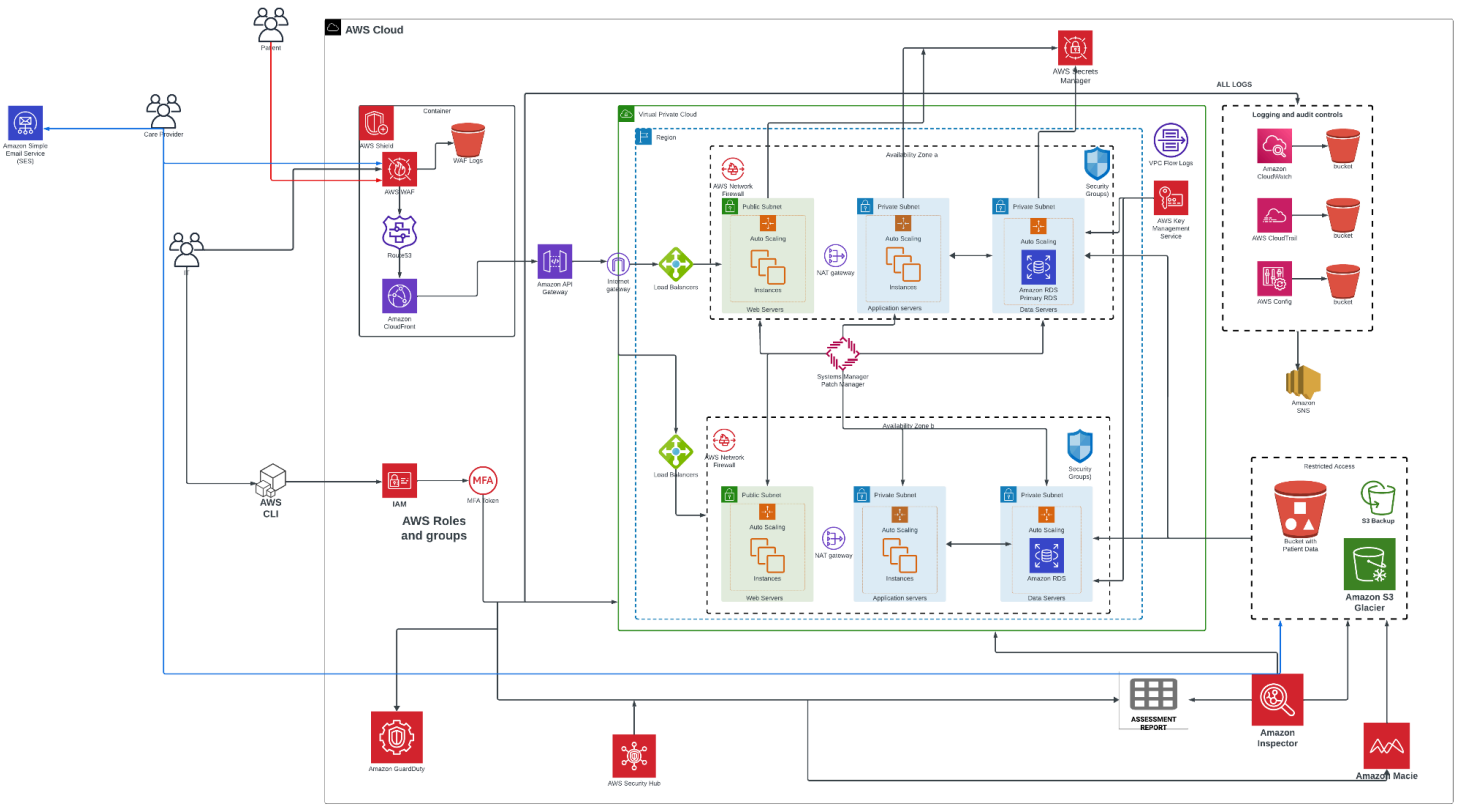
As can be seen in the diagram, the patient is only able to view and access the web portal. The web portal is howsted in a container and is protected from distributed denial of service attacks by AWS shield. Traffic flows through a web application firewall which guards the application against common exploits over the web. An AWS route 53 firewall is also utilized to provide efficient domain name services to the application. Finally, the portal itself is delivered with CloudFront, a content delivery network.

Care Providers can view and access the web portal in the same fashion as the patients as described above. Care providers also have the capability to view all of the patient data which is contained in the S3 bucket and can be seen in the diagram as a blue line from the care providers to the S3 bucket. The S3 bucket has a current backup and is archived in the AWS Glacier service. Care providers also have the capability to send messages out to third parties as can be seen by their ability to access the AWS mail service.

The IT members will have a broader access level as compared to others. The IT members can access the web servers with permissions related to read/write and also permissions that are needed to fix any frontend issues that might occur. This is done by creating different user groups during login and adding all IT members to their user group. IT members have access to the application through either the portal or AWS CLI. Different IAM roles need to be created for the IT Members giving them right permissions to access different assessment reports of the services, perform security audits on the environment and also debug any issues that might arise. Roles like DAtabase Admin, End User Support, system Admin etc. The IT team will not have access to the sensitive data of patients stored in the S3 buckets.

In the architecture, it can be seen that multi AZ deployment is used. Web, application, and data servers are deployed in an availability zone secured by an AWS network firewall and available only to specific security groups. An NAT gateway is used to block inbound and control outbound traffic to the EC2 instance. Both availability zones receive updates and patches from the Systems Manager Patch Manager service. Load balancers are utilized to balance the flow of traffic into the availability zones. AWS Key Management System and AWS Secrets Manager are utilized as key and credential management services. Logs are maintained by the AWS CloudWatch, AWS CloudTrail, and AWS Config services and the IT professionals have access to these logs. Other security and monitoring services are also used in this architecture to promote ultimate security. AWS SecurityHub, AWS Macie, AWS GuardDuty, and AWS Inspector are utilized as monitoring and reporting tools in this architecture.

The proposed architecture diagram is attached below and in a separate file.



Link to the above diagram:
https://lucid.app/lucidchart/27c5e376-b3f8-48e2-b8b1-4c4e1684247f/edit?existing=1&token=14dd850dffbeafd388fbb8eba04b996c1afe85ed4b5cdecbdfa9555ce7a5de0b-eml%3Dlreiter%2540umd.edu%26ts%3D1702599204%26uid%3D190362598&docId=27c5e376-b3f8-48e2-b8b1-4c4e1684247f&shared=true&invitationId=inv_fb96a7c7-2e05-4e00-93dc-1157d992b696&page=0_0#

References

- https://docs.aws.amazon.com/